

NovaPay Risk Assessment Methodology

Practical 5 x 5 information-security risk model

Prepared by	Bola
Organisation	NovaPay Solutions Ltd. (fictional case study)
Industry	FinTech / Digital Payments
Framework	ISO/IEC 27001:2022
Purpose	Cybersecurity GRC portfolio project

Portfolio disclaimer: NovaPay Solutions Ltd. is a fictional organisation adapted from the supplied PayNest capstone case study. No real employer, customer or production data is used.

1. Purpose

This methodology provides a consistent way to identify, score, treat and monitor information-security risks within the NovaPay case study. It is intentionally simple enough for a growing fintech and can be refined as better incident, vulnerability, supplier and availability data becomes available.

2. Risk Statement Structure

I write risk statements using a cause-event-consequence structure: because of a weakness or condition, a threat event could occur, resulting in a business impact. This makes it easier to trace each risk to a treatment action and evidence requirement.

3. Risk Formula

Risk Score = Likelihood x Impact

Score	Likelihood	Impact
1	Rare - exceptional circumstances	Insignificant - minimal operational, financial or confidentiality effect
2	Unlikely - could occur but is not expected	Minor - limited disruption or localized exposure
3	Possible - might occur under normal conditions	Moderate - noticeable impact requiring management attention
4	Likely - expected in many circumstances	Major - serious operational, customer, financial or compliance impact
5	Almost Certain - expected frequently or repeatedly	Severe - material disruption, large-scale compromise or major trust impact

4. Risk Rating Thresholds

Score	Rating	Expected Response
1-4	Low	Manage through routine controls and monitoring.
5-9	Moderate	Treat where practical and monitor.
10-14	High	Formal treatment plan and accountable owner required.
15-25	Critical	Priority treatment and senior-management visibility required.

5. Inherent, Current Residual and Target Residual Risk

Term	Meaning
Inherent Risk	The level of risk before taking existing controls into account.
Current Residual Risk	The risk remaining after considering controls that can be evidenced as operating.
Target Residual Risk	The desired risk level after planned treatment actions are implemented and tested.

Evidence rule

If the case study does not provide evidence that a control is implemented and effective, I do not automatically lower the current residual score. In the portfolio risk register, current residual risk is therefore kept equal to inherent risk where control effectiveness cannot be verified.

6. Risk Treatment Options

Treatment	Meaning
Mitigate	Implement or strengthen controls to reduce likelihood and/or impact.

Treatment	Meaning
Avoid	Stop or redesign the activity that creates unacceptable risk.
Share / Transfer	Allocate part of the exposure through contracts, insurance or a managed service while retaining accountability.
Accept	Management formally accepts residual risk within approved criteria and a defined review date.

7. Review and Acceptance

Risk owners are responsible for treatment progress, but residual risk acceptance remains a management decision. Risk ratings should be reviewed after significant changes, incidents, supplier changes or completion of major remediation actions.